

Taller de criptografía aplicada caso Bitwarden

Análisis de arquitectura criptográfica y controles de protección

Asignatura	SPTI	Periodo	2026-2
Modalidad	Trabajo individual o parejas	Fuente	White paper de seguridad de Bitwarden
Estudiante	José Lancheros Ayora Gina Sofía García Zapata	Fecha	23 de septiembre de 2026
Entregable	Respuestas sustentadas	Extensión	Máximo 6 páginas sin anexos

Propósito del taller

Analizar cómo un gestor de contraseñas aplica principios de criptografía, administración de claves y protección de datos. Las respuestas deben relacionar las decisiones técnicas de Bitwarden con los objetivos de confidencialidad, integridad, autenticidad y disponibilidad.

Caso de estudio

Bitwarden es un gestor de contraseñas libre y de código abierto que almacena credenciales y otra información sensible en una bóveda cifrada. Ofrece aplicaciones web, de escritorio y móviles, extensiones para navegador e interfaz de línea de comandos. La organización puede utilizar el servicio en la nube o desplegarlo en infraestructura propia.

Fuente obligatoria: [Bitwarden Security White Paper](#)

Instrucciones

- Consulte el white paper y responda con sus propias palabras.
- Sustente cada respuesta con la sección, figura o apartado utilizado como evidencia.
- Diferencie con claridad hechos descritos por Bitwarden, inferencias propias y recomendaciones.
- No incluya contraseñas reales, claves, tokens ni datos personales en la entrega.

Preguntas de análisis

1. Arquitectura de conocimiento cero

Explique qué significa el enfoque de conocimiento cero en Bitwarden. Indique qué información puede procesar el servidor y cuál debe permanecer protegida en el dispositivo del usuario.

Respuesta:

Conocimiento cero es básicamente que Bitwarden presta un servicio quedando prácticamente ciego a la información sensible de la persona a la que le está prestando el servicio. Esto no significa que ellos sí puedan tener acceso a la información, sino que literalmente ni ellos mismos, que son los que guardan la información en sus servidores, podrían ver los datos aunque quisieran. Para lograr esto, Bitwarden divide el mundo en dos zonas separadas, el dispositivo y el servidor en la nube. Todo lo que es sensible, como la contraseña maestra, las claves de cifrado y el contenido ya descifrado, vive únicamente en el dispositivo, mientras que el servidor solo recibe información que ya fue transformada localmente antes de salir.

Esa transformación es de dos tipos distintos. La bóveda llega cifrada, lo que significa que con la clave correcta sí se puede revertir a su forma original. La contraseña maestra en cambio llega convertida en un hash, un proceso que no se puede deshacer, y que solo sirve para comparar y confirmar que la contraseña escrita es la correcta. Además de estas dos cosas, el servidor también procesa datos administrativos como el correo electrónico, que cumple otra función, sirve como sal en las funciones de derivación de claves.

Lo que permanece en el dispositivo es todo lo que permite descifrar la información y nunca viaja por la red, es decir la contraseña maestra en texto plano, las llaves derivadas de esa contraseña conocidas como Master Key y Stretched Master Key, la User Symmetric Key ya descifrada, y el contenido de la bóveda ya legible.

Esto se relaciona directamente con la confidencialidad, ya que es lo que este diseño protege ante todo. En un caso hipotético, si alguien se robara la base de datos de Bitwarden, solo se estaría llevando información cifrada y hashes, nada legible. Esta es la lógica del conocimiento cero, reducir al mínimo lo que hay que confiarle al proveedor del servicio.

Esta respuesta se sustenta en las secciones Key security measures y Data protection at rest del white paper de seguridad de Bitwarden, donde se establece que no es posible obtener datos sin cifrar desde los servidores en la nube de Bitwarden.

2. Derivación de la clave maestra

Describe el recorrido desde la contraseña maestra hasta las claves utilizadas para proteger la bóveda. Identifique la función de derivación, la sal y los parámetros de costo descritos en el white paper.

Respuesta:

Este recorrido conecta la contraseña maestra, que es lo único que el usuario memoriza, con la clave real que cifra la bóveda. Bitwarden usa por defecto una función de derivación de claves llamada PBKDF2 con SHA256, que toma la contraseña maestra y la combina con la sal, que en este caso es el correo electrónico del usuario. Esa combinación se procesa repitiendo el algoritmo 600.000 veces, ese número de iteraciones es el parámetro de costo, entre más iteraciones, más lento y más costoso resulta para un atacante intentar adivinar la contraseña por fuerza bruta. El resultado de este primer paso es una clave de 256 bits llamada Master Key.

Esa Master Key todavía se estira una vez más, esta vez con una función distinta llamada HKDF, que significa HMAC based Extract and Expand Key Derivation Function, y que la convierte en una clave de 512 bits llamada Stretched Master Key. Esta es la clave que finalmente se usa para descifrar la Protected Symmetric Key almacenada en el servidor y así recuperar la User Symmetric Key real, la que descifra el contenido de la bóveda.

Por separado, y con un propósito distinto, se genera también un Master Password Hash usando PBKDF2 SHA256, tomando la Master Key como entrada y la contraseña maestra como sal. Este hash sí viaja hacia el servidor, únicamente para autenticar al usuario, y al llegar el servidor lo vuelve a hashear con PBKDF2 y 600.000 iteraciones adicionales usando una sal propia del servidor. Vale la pena mencionar que aunque las cuentas se crean con PBKDF2, el usuario puede cambiar después su función de derivación a Argon2id, un algoritmo más moderno que además de tiempo de cómputo también exige memoria, haciéndolo más resistente frente a ataques con hardware especializado. Esta respuesta se sustenta en las secciones Account creation y Authentication and decryption del white paper.

3. Cifrado e integridad de la bóveda

Identifique los algoritmos o mecanismos utilizados para cifrar la bóveda y verificar su integridad. Explique por qué el cifrado por sí solo no garantiza que los datos no hayan sido modificados.

Respuesta:

Para cifrar el contenido de la bóveda, Bitwarden usa cifrado simétrico AES en modo CBC con claves de 256 bits, combinado con autenticación mediante HMAC. Cada elemento que guardas se convierte primero en un objeto llamado Cipher, y ese Cipher se cifra localmente usando una Cipher Key única y aleatoria de 64 bytes. Esa Cipher Key a su vez se cifra con la User Symmetric Key, si el elemento es personal, o con la Organization Symmetric Key, si pertenece a una organización, antes de enviarse al servidor.

El cifrado con AES protege la confidencialidad, es decir que sin la clave correcta el contenido es ilegible, pero por sí solo no garantiza que los datos no hayan sido modificados. Esto pasa porque cifrado e integridad son propiedades distintas, un atacante que no tiene la clave no puede leer el contenido, pero en modos como CBC sí podría alterar bytes del texto cifrado sin que eso se note de inmediato, produciendo al descifrar información corrupta que el sistema podría aceptar como válida si no hay ninguna verificación adicional. Por eso Bitwarden añade HMAC, que genera un código de verificación a partir de los datos cifrados. Si alguien modifica ese contenido, el HMAC calculado al descifrar no coincide con el original, y el cliente detecta la alteración y la rechaza. El cifrado protege confidencialidad, el HMAC protege integridad y autenticidad del origen, son mecanismos complementarios. Esta respuesta se sustenta en la sección Key security measures y en la explicación de Ciphers de How vault data is encrypted del white paper.

4. Generación y custodia de claves

Analice dónde se generan, almacenan y utilizan las claves criptográficas. ¿Qué controles reducen el riesgo de que una clave quede expuesta al servicio o a un atacante?

Respuesta:

Todas las claves criptográficas se generan, se almacenan temporalmente y se utilizan exclusivamente en el cliente, nunca en el servidor. La generación se hace con un generador de números aleatorios criptográficamente seguro, que el white paper llama CSPRNG, y con él se crean, entre otras, la clave simétrica del usuario al crear la cuenta, el par de claves RSA de cada usuario, la Organization Symmetric Key al crear una organización, y la Cipher Key única de cada elemento.

Para reducir el riesgo de exposición, Bitwarden aplica varios controles. Ninguna clave sin cifrar sale del dispositivo, lo único que llega al servidor son versiones ya cifradas como la Protected Symmetric Key, que sin la clave correcta no sirven de nada. La clave privada RSA de cada usuario se guarda cifrada con su propia User Symmetric Key, así que ni siquiera esa queda expuesta sin autenticación completa. Mientras la aplicación está bloqueada, las claves y los datos de la bóveda se purgan de la memoria de manera agresiva. El usuario puede rotar su clave de cifrado si sospecha un compromiso, lo que genera una clave nueva y re cifra toda la bóveda. Y a nivel

de infraestructura, las claves de la propia plataforma se gestionan en bóvedas internas con controles de acceso estrictos. Esta respuesta se sustenta en las secciones Account creation, Rotating the account encryption key y Key management procedures del white paper.

5. Sincronización entre dispositivos

Explique cómo Bitwarden permite sincronizar una bóveda entre varios dispositivos sin entregar al servidor la información en texto plano. Incluya el papel del cifrado local.

Respuesta:

Bitwarden sincroniza tu bóveda entre dispositivos sin que el servidor vea nunca la información en texto plano, porque el cifrado y el descifrado ocurren únicamente en el cliente. El servidor solo guarda y distribuye datos ya cifrados.

Cuando editas un elemento en cualquier dispositivo, se cifra localmente con su Cipher Key antes de enviarse. Cuando abres la aplicación en otro dispositivo, este descarga la misma información cifrada junto con la Protected Symmetric Key, pero para leerla necesita reconstruir las mismas claves. Como la Master Key y la Stretched Master Key se derivan siempre de la misma contraseña maestra y la misma sal, que es tu correo, cualquier dispositivo en el que ingreses la contraseña correcta recalcula exactamente las mismas claves de forma independiente, sin que viajen por la red. Con la Stretched Master Key recalculada, el nuevo dispositivo descifra localmente la Protected Symmetric Key, obtiene la User Symmetric Key, y descifra cada Cipher. El cifrado local es lo que hace posible toda la sincronización segura, cada dispositivo hace su propio trabajo de forma independiente. Esta respuesta se sustenta en las secciones Authentication and decryption y How vault data is encrypted del white paper.

6. Compartición en organizaciones

Describe cómo se protege la información compartida mediante organizaciones o colecciones. Explique cómo intervienen las claves de usuario, las claves organizacionales y los permisos.

Respuesta:

Para compartir información hay que crear una organización, una entidad que agrupa a los usuarios que quieren compartir datos. Al crearla, se genera aleatoriamente una Organization Symmetric Key, la clave que cifra y descifra todos los elementos de esa organización. Esta clave se cifra con la clave pública RSA del creador usando RSA-OAEP, y ese resultado, la Protected Organization Symmetric Key, es lo que se almacena.

Cuando un nuevo miembro se une, un miembro existente descifra la Organization Symmetric Key con su propia clave privada RSA, y la vuelve a cifrar con la clave pública RSA del nuevo miembro, generando una nueva Protected Organization Symmetric Key exclusiva para esa persona. Aunque cada miembro tiene su propia versión cifrada, todas descifran al mismo valor real de la clave, la misma para toda la organización. Cada usuario solo llega a ella usando su propia clave privada RSA, protegida por su User Symmetric Key personal.

Encima de esta capa criptográfica, Bitwarden usa colecciones, grupos, roles y permisos para controlar qué puede ver y hacer cada miembro. Estas herramientas no cambian la clave que protege los datos, esa sigue siendo la misma para todos los miembros confirmados, pero sí controlan a nivel de aplicación quién accede a qué colección y qué acciones puede realizar. Esta respuesta se sustenta en las secciones When you create an organization, When users join an organization y Access controls, permissions and roles del white paper.

7. Autenticación y cifrado

Diferencie la función de la autenticación, el cifrado de la bóveda y el transporte seguro. ¿Qué riesgo permanece si un atacante obtiene las credenciales de acceso, pero no puede derivar correctamente la clave de cifrado?

Respuesta:

Aunque suelen mezclarse, la autenticación, el cifrado de la bóveda y el transporte seguro cumplen funciones distintas. La autenticación confirma que eres quien dices ser, comparando un Master Password Hash con el hash guardado en el servidor, sin descifrar nada. El cifrado de la bóveda ocurre por completo en el cliente y depende de derivar correctamente la Stretched Master Key a partir de tu contraseña real, única forma de descifrar la Protected Symmetric Key. El transporte seguro es la capa de TLS y HTTPS que protege la comunicación mientras viaja por internet, evitando interceptación, pero no tiene relación con si los datos viajan cifrados de extremo a extremo.

Si un atacante obtuviera tus credenciales de acceso, pero no conoce tu contraseña maestra real, no podría derivar correctamente la Stretched Master Key, y sin ella la Protected Symmetric Key sigue siendo un bloque cifrado inútil. El riesgo que permanece es que el atacante podría, en el peor caso, entrar a la cuenta y ver que existen elementos guardados, pero seguiría sin poder leer ni una sola contraseña, porque el cifrado depende de un secreto distinto al que usó para autenticarse. Esta respuesta se sustenta en las secciones Authentication and decryption y Data protection in transit del white paper.

8. Análisis de amenazas

Compare dos escenarios: robo de la base de datos del servidor y compromiso del dispositivo de un usuario con la bóveda desbloqueada. Determine cuál información estaría expuesta y qué controles resultarían relevantes en cada caso.

Respuesta:

Estos dos escenarios exponen información muy distinta. En el robo de la base de datos del servidor, un atacante solo obtendría información cifrada, hashes de contraseñas maestras y datos administrativos como correos, nunca contenido legible. Los controles relevantes son las iteraciones altas en la derivación, que encarecen adivinar contraseñas por fuerza bruta contra esos hashes, el cifrado AES de 256 bits, y que las claves nunca se almacenan sin proteger. El impacto real acá es bastante limitado si los usuarios usaron contraseñas maestras fuertes.

El compromiso del dispositivo con la bóveda desbloqueada es mucho más grave. Ahí la User Symmetric Key y los datos ya descifrados están disponibles en memoria, así que un atacante con acceso al dispositivo en ese momento tendría acceso directo y en texto plano a toda la información guardada, sin romper ningún cifrado. Los controles relevantes ya no son criptográficos sino de seguridad del dispositivo, como mantener el sistema actualizado, activar el bloqueo automático por inactividad, usar biometría o PIN, y estar alerta ante malware tipo keylogger. La conclusión es clara, el diseño criptográfico protege muy bien contra un servidor comprometido, pero la seguridad del dispositivo del usuario sigue dependiendo de sus buenas prácticas. Esta respuesta se sustenta en las secciones Data protection at rest y Threat model and attack surface analysis overview del white paper.

9. Transparencia y aseguramiento

Evalúe el aporte del código abierto, las auditorías de seguridad y la divulgación de componentes criptográficos. Relacione su respuesta con el principio de Kerckhoffs.

Respuesta:

Bitwarden basa buena parte de su confiabilidad en la transparencia, no en mantener sus mecanismos en secreto. Todo el código fuente está publicado en GitHub y cualquier persona puede revisarlo o auditarlo. Además, empresas externas auditan el código al menos una vez al año, y el programa de divulgación de vulnerabilidades con HackerOne invita a investigadores independientes a reportar fallos. A esto se suman certificaciones como SOC2 Tipo II, SOC3 e ISO 27001.

Todo esto conecta con el principio de Kerckhoffs, que dice que la seguridad de un sistema criptográfico debe depender únicamente del secreto de la clave, y no del secreto del diseño. Bitwarden lo cumple casi al pie de la letra, cualquiera puede leer exactamente cómo funciona PBKDF2 o cómo se deriva la Stretched Master Key, y esa información no le sirve a un atacante si no tiene la contraseña maestra real de la víctima. El código abierto y las auditorías fortalecen la seguridad porque permiten que expertos externos encuentren errores antes que un atacante, demostrando que el sistema no depende de que nadie descubra cómo funciona por dentro. Esta respuesta se sustenta en las secciones Key security measures, Code assessments y Auditability and compliance del white paper.

10. Conclusión crítica

Formule una conclusión sobre la solidez del modelo de seguridad. Proponga dos recomendaciones concretas para una organización que adopte Bitwarden y justifique cada una.

Respuesta:

En conjunto, el modelo de seguridad de Bitwarden es sólido porque separa muy bien las responsabilidades, el servidor nunca tiene la posibilidad técnica de leer los datos del usuario, y el diseño se apoya en algoritmos estándar revisados públicamente como AES, PBKDF2, HMAC y RSA. La principal fortaleza es que incluso si el proveedor fuera comprometido, la confidencialidad se mantendría intacta gracias al conocimiento cero. La principal debilidad es que toda la seguridad termina dependiendo de un único punto, la fortaleza de la contraseña maestra y la seguridad del dispositivo donde se usa.

Propongo dos recomendaciones concretas para una organización que adopte Bitwarden. La primera es exigir el inicio de sesión en dos pasos para todos los miembros, porque agrega una barrera adicional en la autenticación que sigue siendo útil incluso si una contraseña maestra llega a filtrarse en otro sitio. La segunda es migrar la función de derivación de PBKDF2 a Argon2id, que además del costo en tiempo también exige memoria, encareciendo mucho más los ataques con hardware especializado como GPUs. Ninguna de las dos cambia la arquitectura de Bitwarden, solo aprovechan mejor lo que la plataforma ya ofrece.

Criterios de evaluación

Criterio	Qué se espera	Peso	Puntaje
Comprensión técnica	Explica correctamente arquitectura, claves, cifrado, integridad y sincronización.	35 %	
Uso de evidencia	Relaciona cada respuesta con apartados concretos del white paper.	20 %	

Análisis de riesgos	Distingue amenazas, impactos y controles en los escenarios propuestos.	20 %	
Argumentación	Presenta conclusiones justificadas y recomendaciones viables.	15 %	
Claridad y presentación	Utiliza lenguaje técnico preciso, orden y referencias completas.	10 %	

Lista de verificación antes de entregar

- Respondí las diez preguntas.
- Incluí evidencia del white paper.
- Diferencié análisis propio y contenido de la fuente.
- Verifiqué que la entrega no contenga secretos ni datos personales.